

Block 11b: malformed Solana transaction refusal before schema consent

Date: 2026-09-28. Auditor: Codex /root. Isolated checkout: /private/tmp/kk715-11a. Immediate target: fork audit/715-11a-test-board-bootstrap-20260928 at fa02818bc4b722d81ba9c977ff06bfc12b2083cf (PR #879), stacked on CI prerequisite PR #880 and accepted Block 10. Code generation predecessor: 7eceaffffa0d305091c46f13e432d9282615370c; predecessor merge: 85627b3d38335fc72090b9bc06af3d9dc8be9b54. Final containing head and hosted CI belong in the PR body. Main-worktree master template SHA256 at intake: b3ec05e8aeb6db1dfce462116fc8f2bcb57bb7577f627f226665fb0e89b79355.

1. Scope and source reconciliation

The adjacent four-path diff adds an immediate `SOL_TX_REVIEW_MALFORMED` refusal in `fsm_msgSolanaSignTx`, adds all-prefix schema truncation assertions to native tests, advances the companion Python pin to `aae89d378d889b3872696469fe363cf570e5ac4c` (companion PR #122), and aligns the CI report's Python PR link. The CI event-authority regression test is inherited from 11p and is outside this adjacent diff. The product handler, runtime schema parser and inherited consent rules were traced at the pinned source. No other product path or dependency pin changes in this unit. Direct and nested submodules are initialized and clean.

Finding S11-01 was reproduced on the historical source base `db7c711a6c824c42e7096d4867429bbe94cb6ffb`: partial parser output could populate instructions despite a malformed transaction; a matching runtime schema then entered confirmation before the later fallback malformed check. The first guard now zeroes the derived node, sends `SyntaxError`, restores the home screen and returns before signer/schema/consent processing. The later fallback remains. Truncation assertions cover every prefix of canonical v1 and v2 schema payloads; the companion Python pin carries wire regressions for malformed legacy trailing bytes and truncated v0 lookup sections, with and without schema, plus valid-signing controls.

Direct pins match the predecessor except `deps/python-keepkey: code-signing-keys` `a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec`; `deps/crypto/trezor-firmware` `8a392f70a5d5575ece3dfb35f115d4a4b27f497c`; `deps/device-protocol` `5fec9e6906a340be5eb3d795ec746769065b2db8`; `deps/googletest` `7888184f28509dba839e3683409443e0b5bb8948`; `deps/python-keepkey` `aae89d378d889b3872696469fe363cf570e5ac4c`; `deps/qrenc/QR-Code-generator` `6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8`; `deps/sca-hardening/SecAESSTM32` `71d356a1141624994cf613bd2d2583892e8e6d5a`.

2. Finding and security closure

The sensitive state is the raw transaction and derived signing node, with runtime schema metadata supplied by the host. The observer is the device user at a Solana confirmation screen and the host receiving a signature/failure. The full product build dispatches this handler; Bitcoin-only excludes Solana by product configuration. The allowed output for malformed trailing/truncated transaction encodings is `SyntaxError` before any schema confirmation and no signature. Equivalent malformed representations include legacy trailing bytes and truncated v0 lookup sections, each with a matching or absent schema. A valid matching-schema transaction remains signable after normal consent. The node must be wiped on the early failure path.

Historical emulator wire XML in the cumulative Block 11 archive shows three schema-bearing malformed subcases failing on the old source: they reached confirmation and returned `ActionCancelled` when the test declined. The corresponding fixed historical XML has zero failures, including valid controls. That baseline is a behavior-distinguishing negative control on an earlier source identity, not exact-head proof for this split. The current split source passed 44/44 focused native Solana tests and 669/669 full firmware tests; Bitcoin-only passed 143/143 firmware tests and dispatches no Solana cases. The report-authority suite inherited from 11p passed 18/18. Current exact-head emulator wire, ARM and report qualification remain hosted gates.

The deterministic ten-member `715-11b-controls-20260928.tgz` archive has SHA256 `f3ea6ae0cf903ecdb383ba80d7131390c6ddb82de2628146086e847b47ee22a9`. It binds nine raw logs/XML files, the code/source identities, and historical archive provenance. Every member hash verifies and a changed XML member is rejected. The four adjacent source/pin paths are byte-identical between the native-build code head and the merge-prepared head, so the native results apply to this frozen material source. The historical wire receipt is additionally documented in `715-11-malformed-schema.md` on cumulative PR #877.

3. Local and external checkpoint

Implementation, source-level negative control and targeted native assertions pass for the malformed-consent property. Local full and Bitcoin-only firmware suites and report tests pass. The final post-edit preflight, exact-head hosted CI, PDF/inventory check and Copilot delivery are recorded after report freeze in the PR body. This unit has a fresh three-round review budget under the owner's consecutive split authorization; no review has been requested here. Physical device consent, actual power interruption, release merge and publication are separate gates.

4. Complete adjacent Git inventory

Inventory base: `fa02818bc4b722d81ba9c977ff06bfc12b2083cf`. Code predecessor: `7eceaffffa0d305091c46f13e432d9282615370c`; prerequisite merge: `85627b3d38335fc72090b9bc06af3d9dc8be9b54`. The first containing report predecessor and final head are recorded in the PR body. Reproduce from the immutable immediate base to that final head with `git diff --numstat fa02818bc4b722d81ba9c977ff06bfc12b2083cf..FINAL_PR_HEAD`. Binary counts use Git's dash.

Added	Deleted	Path
-------	---------	------